

Data Protection Policy – Version 3.2

Effective Date: January 1, 2025

Owner: Information Security Team

1. Scope and Purpose

1.1 This policy applies to all employees, contractors, vendors, and third parties who access, process, or store customer information on behalf of the Company.

1.2 Customer information includes but is not limited to: full names, email addresses, billing addresses, payment card details, support ticket contents, product usage telemetry, and any personally identifiable information (PII) as defined under applicable privacy laws.

1.3 The purpose of this policy is to ensure that customer data is handled confidentially, with integrity, and available only to authorized personnel for legitimate business purposes.

2. Approved Platforms and Storage

2.1 Customer data must only be stored on company-approved platforms that have executed a Data Processing Agreement (DPA) with the Company. Approved platforms include: Salesforce (customer relationship management), AWS S3 buckets with proper encryption and access controls, and internal SharePoint sites restricted to the relevant team.

2.2 Storing customer data on unapproved platforms such as Google Drive personal accounts, Dropbox personal accounts, iCloud, or any consumer-grade file sharing service is strictly prohibited.

2.3 All approved storage locations must use at least AES-256 encryption at rest and TLS 1.2+ encryption in transit.

3. Data Sharing and Third-Party Access

3.1 Customer data may be shared with external parties only when:

a) The external party has signed a non-disclosure agreement (NDA) that includes data protection clauses,

b) Written approval has been obtained from the Information Security Team via the formal data sharing request process (form available on the InfoSec portal), and

c) The minimum necessary data principle is applied – only the specific data fields required for the third party's legitimate purpose are shared.

3.2 Any data sharing that involves sensitive data (e.g., payment card numbers, government IDs, health information) requires additional approval from the Legal Department and the Chief Privacy Officer.

3.3 A record of all data sharing requests and approvals must be retained for at least 3 years in the compliance audit log.

4. Personal Devices and Remote Access

4.1 Customer data must not be stored on personal devices including personally owned laptops, smartphones, tablets, USB flash drives, external hard drives, or any other removable media.

4.2 Accessing customer data from a personal device is permitted only through the Company's virtual desktop infrastructure (VDI) or browser-based access with no local caching. Downloading or syncing data for offline access is forbidden.

4.3 If an employee believes they have inadvertently stored customer data on a personal device, they must immediately disconnect the device from the internet, avoid copying or modifying any files, and report the incident to security@company.com within one hour.

5. Reporting Violations

5.1 Any known or suspected violation of this Data Protection Policy must be reported to security@company.com within 24 hours.

5.2 Reports may be made anonymously through the Ethics Hotline (1-800-555-0199) if the reporting party wishes to remain anonymous.

5.3 Failure to report a known violation may result in disciplinary action up to and including termination of employment or contract.

6. Consequences of Non-Compliance

6.1 Employees who violate this policy may face disciplinary action ranging from a written warning to immediate termination, depending on the severity and whether the violation was intentional or negligent.

6.2 Contractors and vendors found in violation will have their access revoked immediately and may be subject to contractual penalties including financial damages for data breaches.

6.3 The Company will notify affected customers and relevant regulatory authorities as required by law in the event of a data breach involving customer information.